

Your Clocks Have Ears!

Timing-Based Browser-Based
Local Network Port Scanner

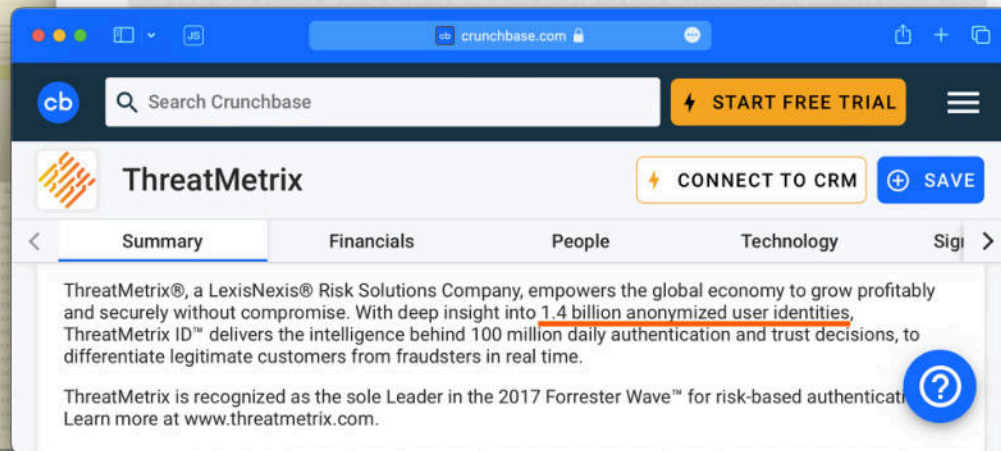
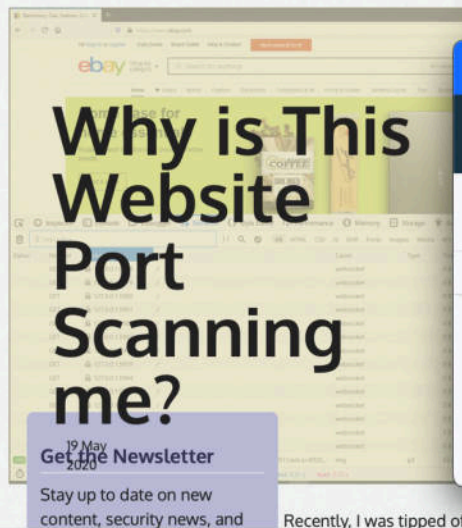
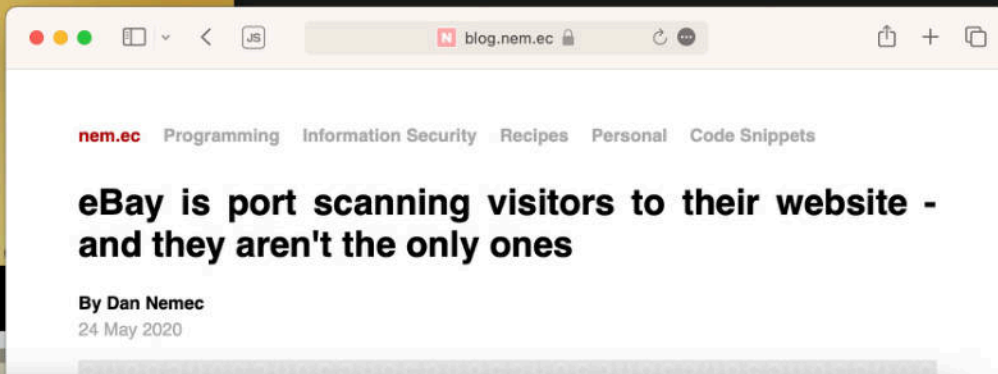
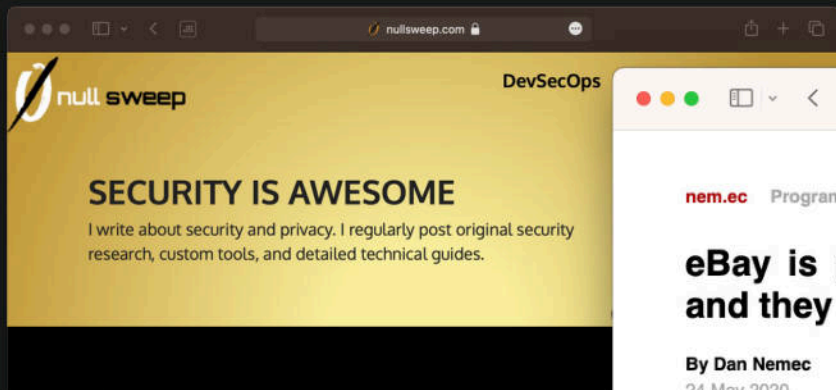
Dongsung "Donny" Kim

About Me



- Dongsung "Donny"^{Surname} Kim
- IT-Security Expert @ Security Office
- Twitter @kid1ng ▪ Bluesky @kidi.ng
- Discord kiding ▪ Website kidi.ng
- Based in Sweden and South Korea
- Part of the Truesec Group
- <https://security-office.co.kr>



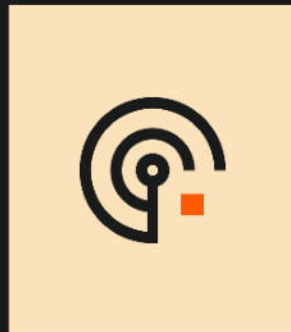


Browser-Based Port Scanning

- Privacy implication: fingerprinting visitors
 - Tracking with characteristics unique to each user, browser, hardware setup
- Security implication: uncovering intranet services
 - A foothold for XSS, CSRF

Previous Works

- `<img>`, `<iframe>`, `<script>`, WebRTC, WebSocket
- Browsers mitigated them to some extent



Timing Measurement on Fetch

```
1  async function measure(ip, port, timeout, https) {
2      const ctrl = new AbortController();
3      const timer = setTimeout(() => ctrl.abort(), timeout / 1_000);
4
5      let t0 = performance.now();
6      try {
7          await fetch(
8              `http${https ? 's' : ''}://${ip}:${port}`,
9              { signal: ctrl.signal }
10         );
11     } catch (e) {
12     } finally {
13         let t1 = performance.now();
14         clearTimeout(timer);
15
16         const elapsed = (t1 - t0) * 1_000;
17         return elapsed;
18     }
19 }
```

- We can observe:
 - Elapsed time of a fetch request
- We cannot observe:
 - Response data
 - Request data
 - Other than scheme, ip, port
 - Error data
 - Other than "TypeError: Failed to fetch"

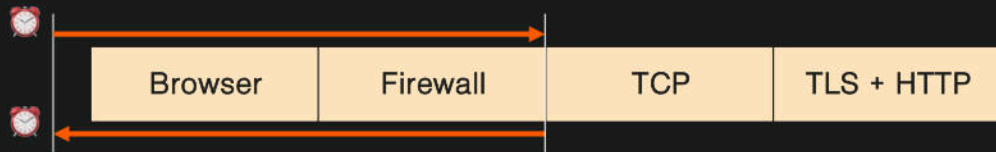


States and Hypotheses

- If port is closed and firewall drops packets, or host is unreachable:



- If port is closed and firewall rejects packets:



- If port is open and a process is listening:



➡ Distinct timing differences
depending on the state of a port



Three Techniques

Finding Open Ports on
the Localhost

1 ■

Finding
the Router

2 ■

Finding Open Ports on
the LAN Clients

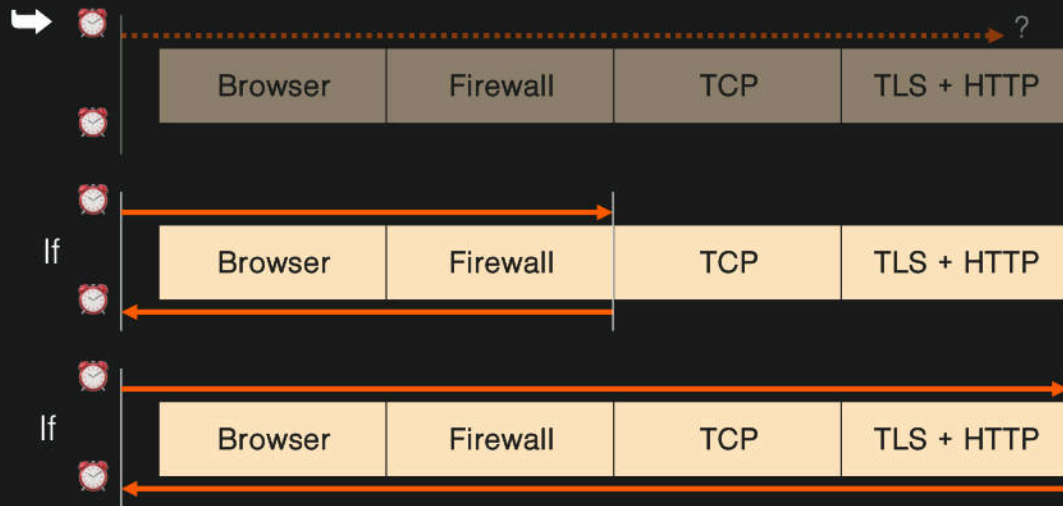
3 ■



1 ■ Finding Open Ports on the Localhost

Observations and States

- Firewall always rejects packets when port is closed*
- Host is always reachable



■ Port is closed
and firewall drops packets,
or host is unreachable:

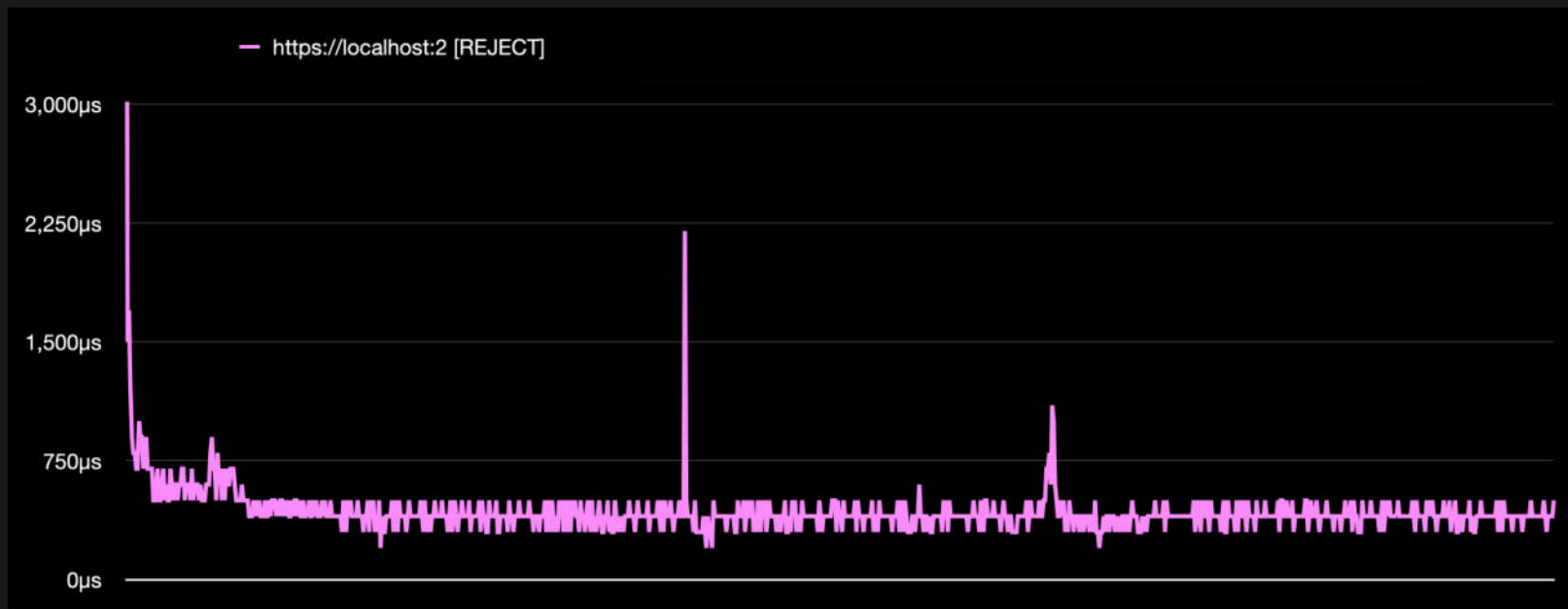
■ Port is closed
and firewall rejects packets

■ Port is open
and a process is listening

1 ■ Finding Open Ports on the Localhost

Algorithm

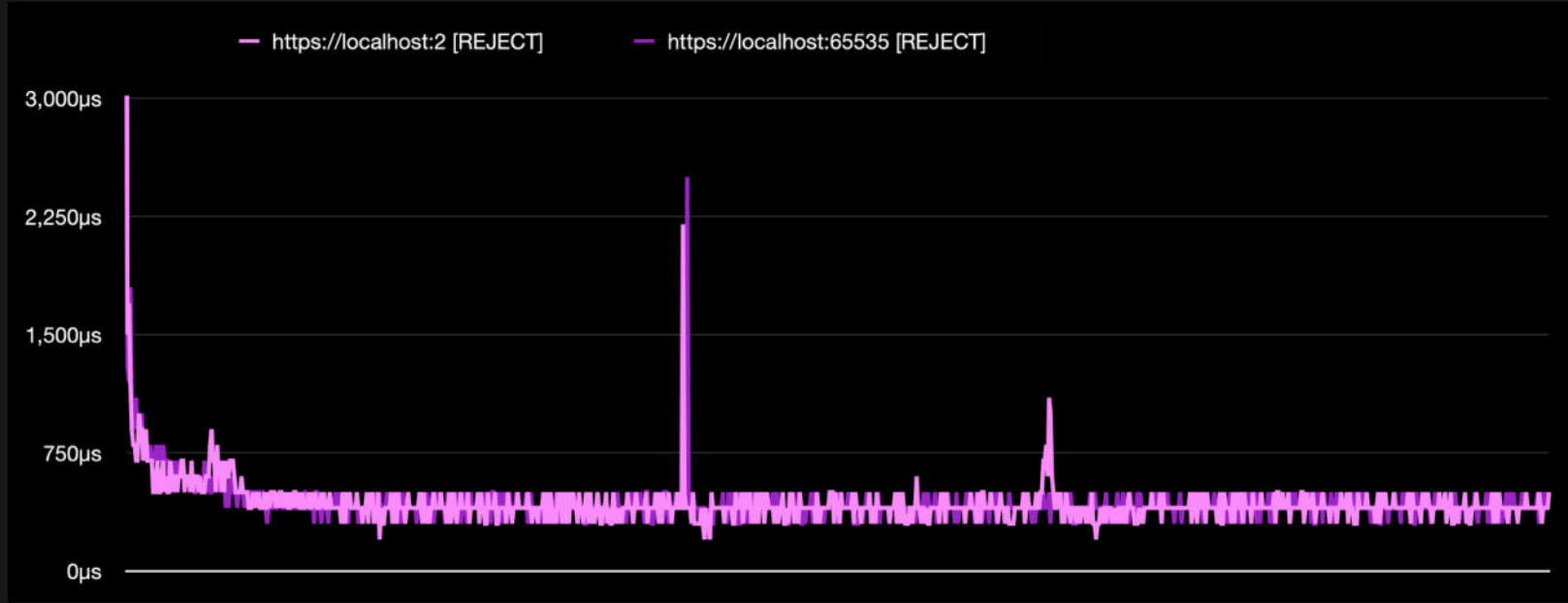
1. Make multiple fetches to localhost:2, a port that is generally closed, and calculate the average timing as a control



1 ■ Finding Open Ports on the Localhost

Algorithm

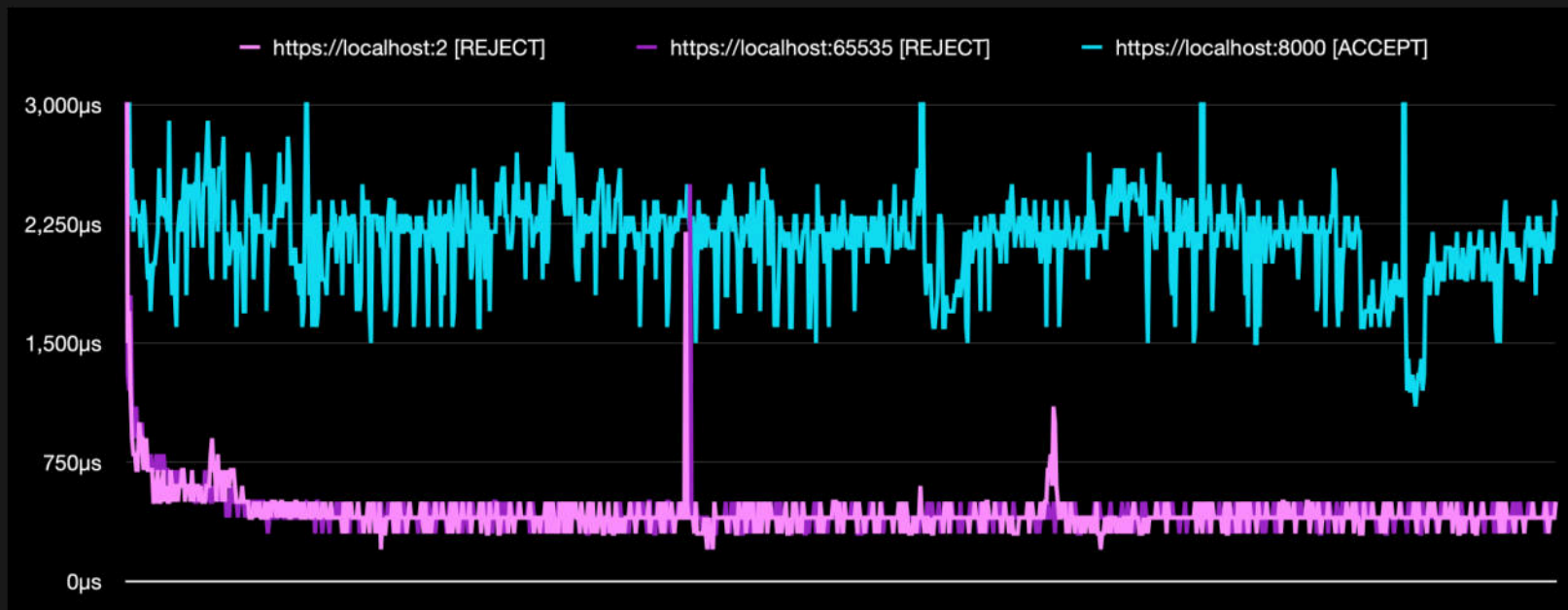
2. If a fetch takes a similar time as the control, the port is closed



1 ■ Finding Open Ports on the Localhost

Algorithm

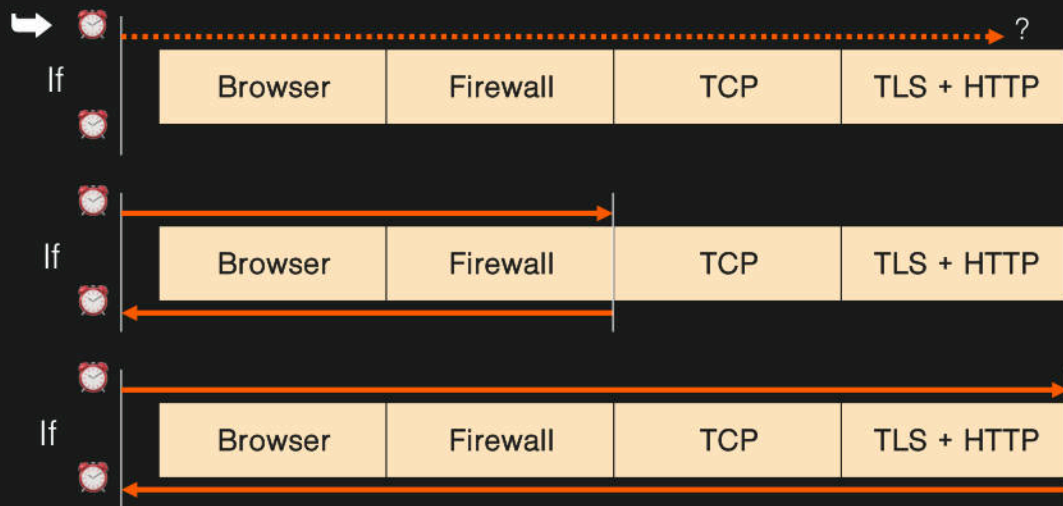
2. If a fetch takes a similar time as the control, the port is closed
3. If a fetch takes significantly more time than the control, the port is open



2 ■ Finding the Router

Observations and States

- We only care if host is responsive or not



- Port is closed and firewall drops packets, or host is unreachable
➡ Host is unresponsive
- Port is closed and firewall rejects packets
➡ Host is responsive
- Port is open and a process is listening
➡ Host is responsive



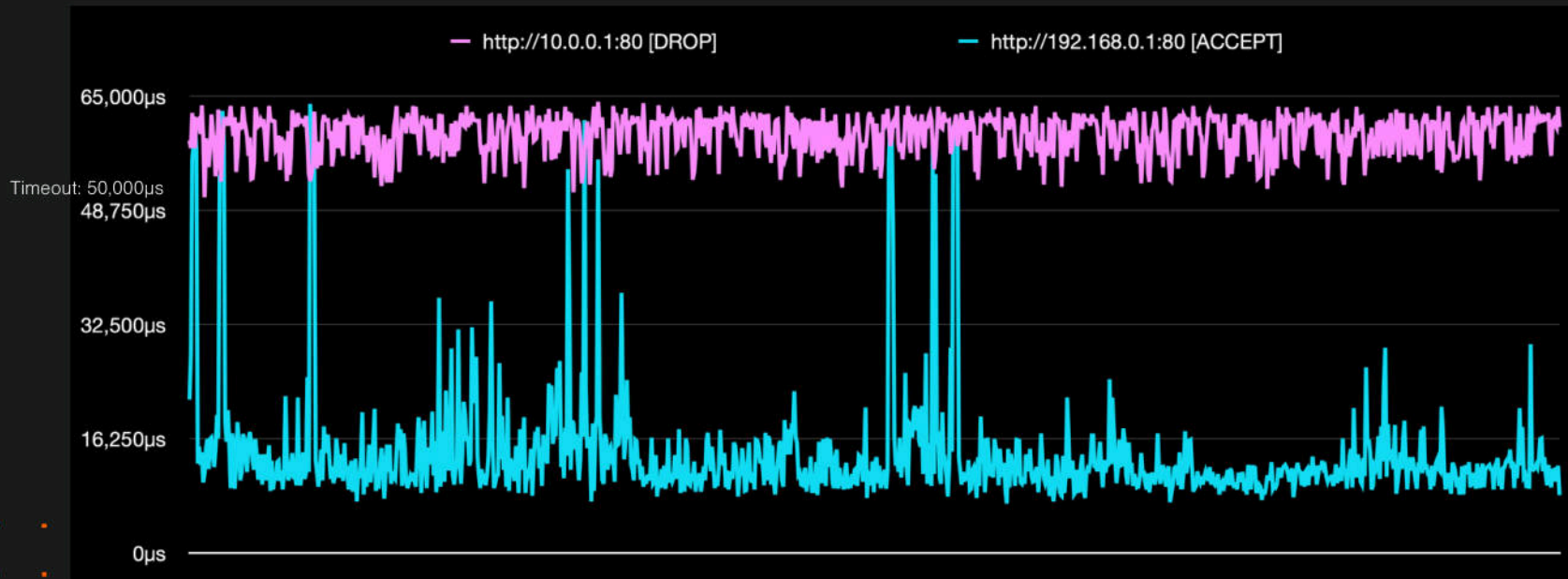
2 ■ Finding the Router Algorithm

1. If a fetch times out, the host is unresponsive



2 ■ Finding the Router Algorithm

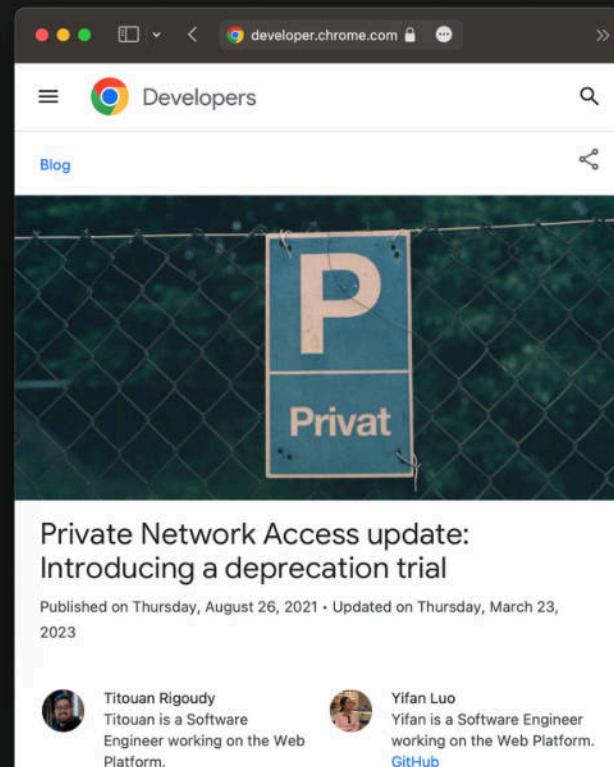
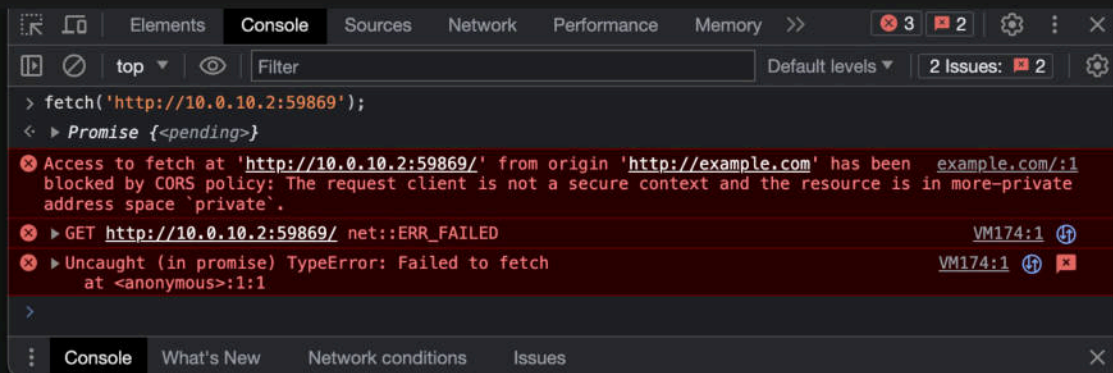
1. If a fetch times out, the host is unresponsive
2. If a fetch ends before the timeout, the host is responsive



3 ■ Finding Open Ports on the LAN Clients

Observation: Private Network Access

- On Chrome by default, requests to private network resources are allowed only from HTTPS web pages
- HTTP requests to a client on the LAN from an HTTP web page would return a CORS error



3 ■ Finding Open Ports on the LAN Clients

Observation: Private Network Access

- How the CORS error gets returned:

W3C “Private Network Access”

3.1.1. Secure context restriction

5. The [HTTP-network fetch](#) algorithm is amended to add 3 new steps right after checking that the newly-obtained *connection* is not failure:

1. Set *response*'s [IP address space](#) to *connection*'s [IP address space](#).
2. Let *privateNetworkAccessCheckResult* be the result of running [Private Network Access check](#) for *fetchParams*' [request](#) and *connection*.
3. If *privateNetworkAccessCheckResult* is a [network error](#), return *privateNetworkAccessCheckResult*.



3 ■ Finding Open Ports on the LAN Clients

Observation: Private Network Access

- How the CORS error gets returned:

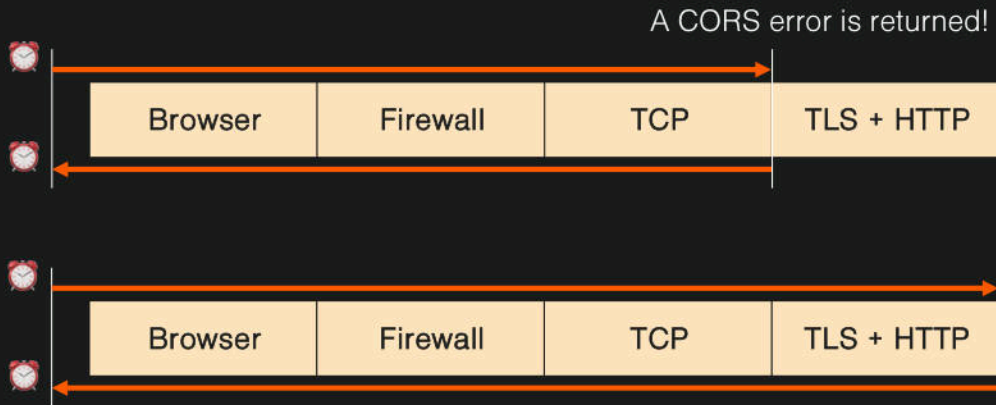
W3C “Private Network Access”

3.1.1. Secure context restriction

5. The [HTTP-network fetch](#) algorithm is amended to add 3 new steps right after checking that the newly-obtained *connection* is not failure:

- New states and hypotheses

- When fetching HTTP local IP from an HTTP web page, if port is open and a process is listening:
- When fetching HTTPS local IP from an HTTP web page, if port is open and a process is listening:



3 ■ Finding Open Ports on the LAN Clients

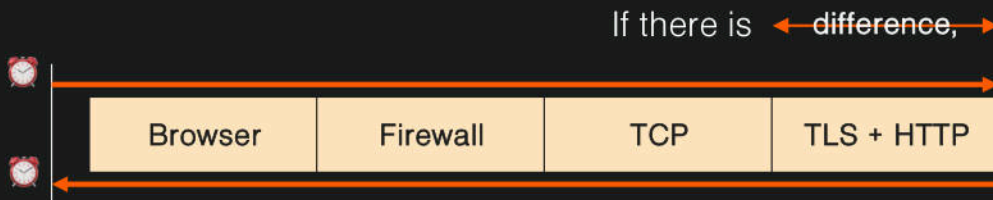
Observations and States

- When fetching HTTP local IP from an HTTP web page



A CORS error is returned!

- When fetching HTTPS local IP from an HTTP web page



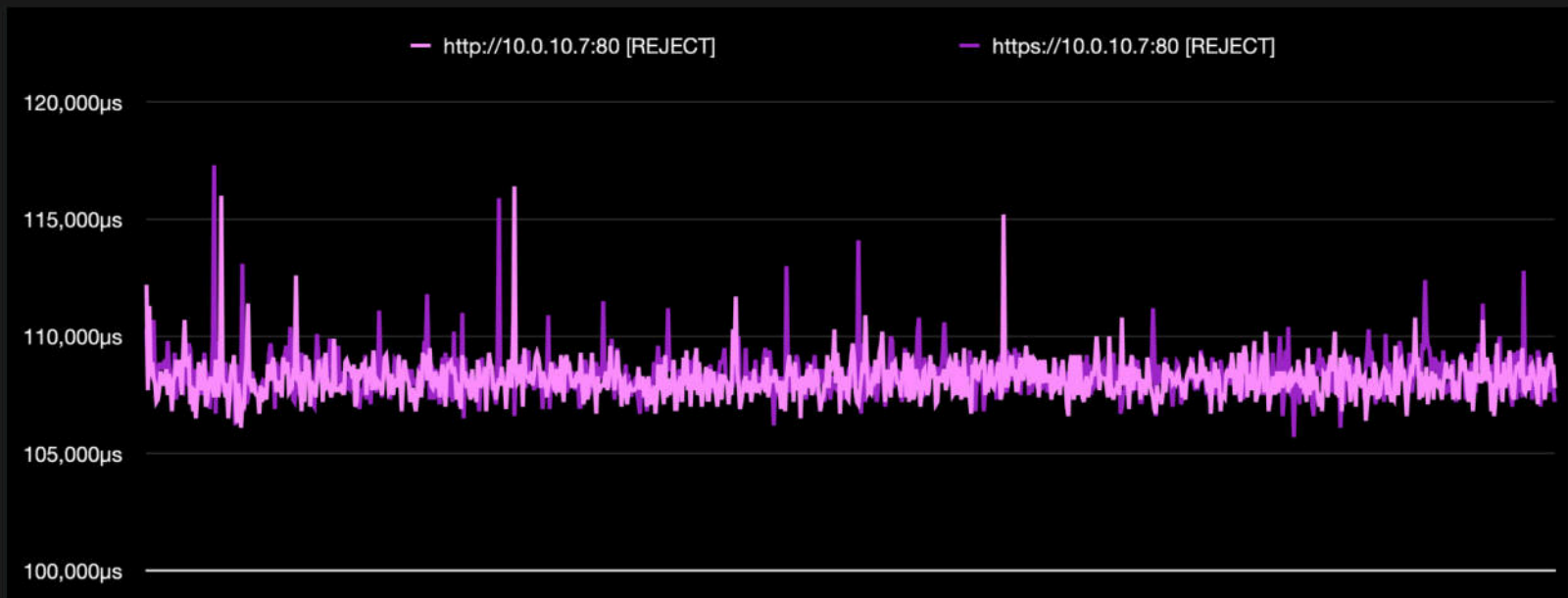
- Port is open and a process is listening



3 ■ Finding Open Ports on the LAN Clients

Algorithm

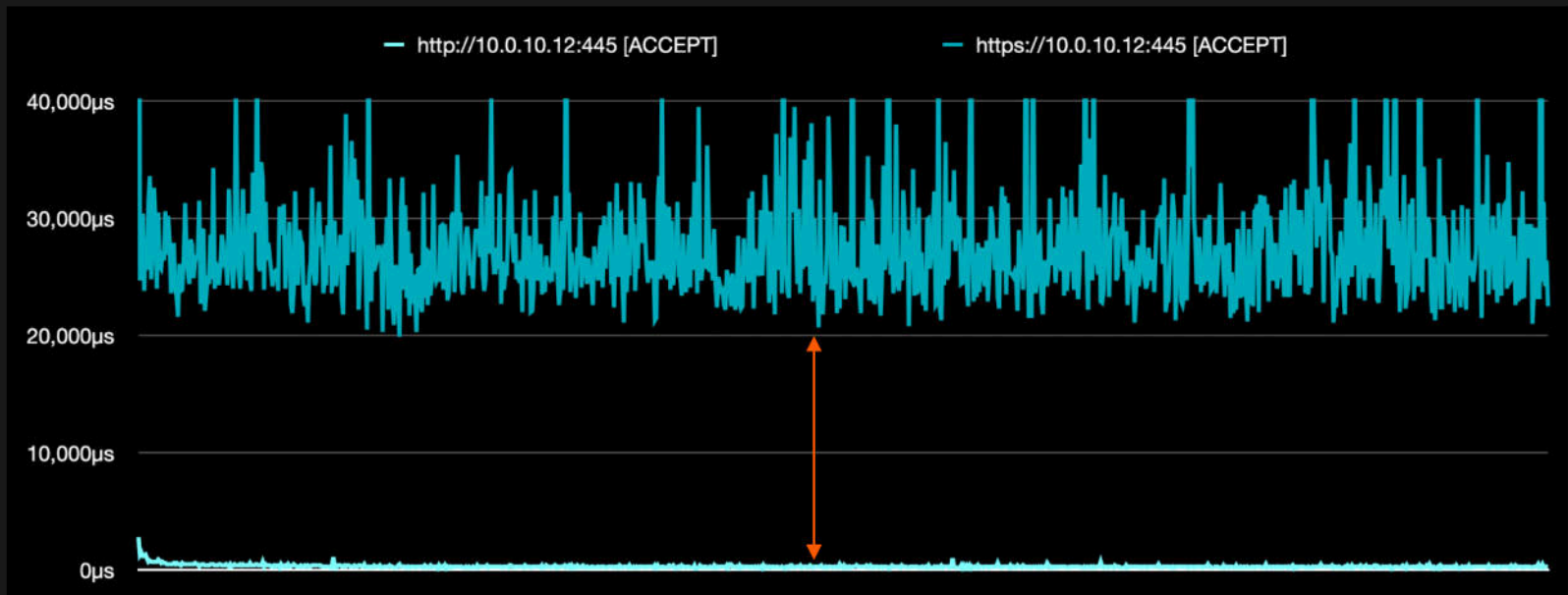
1. If an HTTPS fetch takes a similar time as an HTTP fetch, port is closed and firewall rejects packets



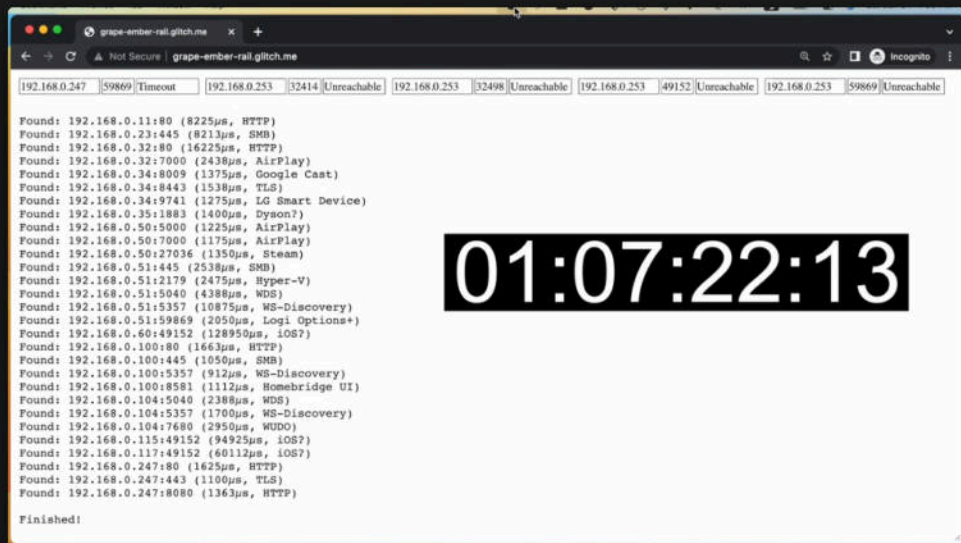
3 ■ Finding Open Ports on the LAN Clients

Algorithm

2. If an HTTPS fetch is significantly slower than an HTTP fetch, port is open and a process is listening



Demo



```
Found: 192.168.0.11:80 (8225µs, HTTP)
Found: 192.168.0.23:445 (8213µs, SMB)
Found: 192.168.0.32:80 (16225µs, HTTP)
Found: 192.168.0.32:7000 (2438µs, AirPlay)
Found: 192.168.0.34:8009 (1375µs, Google Cast)
Found: 192.168.0.34:8443 (1538µs, TLS)
Found: 192.168.0.34:9741 (1275µs, LG Smart Device)
Found: 192.168.0.35:1883 (1400µs, Dyson?)
Found: 192.168.0.50:5000 (1225µs, AirPlay)
Found: 192.168.0.50:7000 (1175µs, AirPlay)
Found: 192.168.0.50:27036 (1350µs, Steam)
Found: 192.168.0.51:445 (2538µs, SMB)
Found: 192.168.0.51:2179 (2475µs, Hyper-V)
Found: 192.168.0.51:5040 (4388µs, WDS)
Found: 192.168.0.51:5357 (10875µs, WS-Discovery)
Found: 192.168.0.51:59869 (2050µs, Logi Options+)
Found: 192.168.0.60:49152 (12895µs, iOS?)
Found: 192.168.0.100:80 (1663µs, HTTP)
Found: 192.168.0.100:445 (1050µs, SMB)
Found: 192.168.0.100:5357 (912µs, WS-Discovery)
Found: 192.168.0.100:8581 (1112µs, Homebridge UI)
Found: 192.168.0.104:5040 (2388µs, WDS)
Found: 192.168.0.104:5357 (1700µs, WS-Discovery)
Found: 192.168.0.104:7680 (2950µs, WUDO)
Found: 192.168.0.115:49152 (94925µs, iOS?)
Found: 192.168.0.117:49152 (60112µs, iOS?)
Found: 192.168.0.247:80 (1625µs, HTTP)
Found: 192.168.0.247:443 (1106µs, TLS)
Found: 192.168.0.247:8080 (1363µs, HTTP)

Finished!
```

your-lan.js

<http://lan.kidi.ng>

macOS recommended

Chrome required

Conclusion

- A website can scan your local network

Limitations

- False positives and false negatives
- Needs optimization

Takeaways

- Use Tor browser for privacy & security
- Use ad blockers to avoid malicious tracking scripts
- VPNs can't be a mitigation



Thank you!



www.truesec.com / www.security-office.co.kr



twitter.com/truesec



linkedin.com/company/truesec